ID

HANDWRITTEN WORK NOTES

Microsoft Entra ID

Users, groups, permissions, policies, service principals, service accounts, managed identities and more

Learn the big picture
Who signs in, how identity is proven, and how access is granted.

Use at work
Quick comparisons, practical Azure examples, troubleshooting and operating checks.

Remember faster
Mind maps, formulas, diagrams and plain-language definitions.

Build safely
Least privilege, MFA, PIM, workload federation and managed identity guidance.

IDENTITY -> AUTHENTICATION -> POLICY -> TOKEN -> AUTHORIZATION

MFA

Study edition: August 2026

Formerly Azure Active Directory (Azure AD)

What is Microsoft Entra ID?

A cloud identity and access management service - the security front door for people, applications and devices.

Simple definition: Entra ID helps answer two questions: **Who are you?** and **What are you allowed to access?**

Office security analogy

Employee register

The directory stores users, groups, devices and applications.

ID card check

Authentication verifies that the identity is genuine.

Door access list

Authorization checks the roles and permissions assigned.

Security rule book

Conditional Access evaluates sign-in conditions and risk.

Main use cases

- Employees sign in once to Azure, Microsoft 365 and company applications.
- Administrators control access to Azure resources through Azure RBAC.
- MFA and Conditional Access protect sensitive sign-ins.
- Applications and automation receive non-human workload identities.
- Partners are invited as guests with limited access.
- Company devices can become part of access decisions.
- On-premises Active Directory identities can be synchronized to the cloud.

Key point

Entra ID does not contain your VMs, storage accounts or databases. It contains the **identities** used to access them.

The access journey

Identity — User, app or device → **Authentication** — Prove who you are → **Policy check** — MFA, device, risk → **Token** — Time-limited proof → **Authorization** — Role + scope

Memory sentence: Entra ID identifies the caller, policy checks the sign-in, a token is issued, and the resource decides whether the requested action is allowed.

Master mind map

Use this page as the map for every Entra ID topic you study later.

MICROSOFT ENTRA ID

Tenant and directory

Organization boundary, tenant ID, domains and directory objects.

Human identities

Member users, guest users, cloud-only users and synchronized users.

Workload identities

App registrations, service principals, managed identities and automation accounts.

Device identities

Registered, joined and hybrid joined computers and mobile devices.

Authentication

Password, MFA, passkeys, certificates, SSO and passwordless methods.

Authorization

Permissions, roles, role assignments, scopes, API permissions and consent.

Policies

Conditional Access, authentication methods, password protection and app consent rules.

Security and governance

PIM, access reviews, identity risk, lifecycle workflows, sign-in logs and audit logs.

Questions Entra ID answers

- Does this identity exist?
- Can it successfully authenticate?
- Do current conditions meet policy?
- Which token claims should be issued?
- Which role or app assignment applies?

Questions the target resource answers

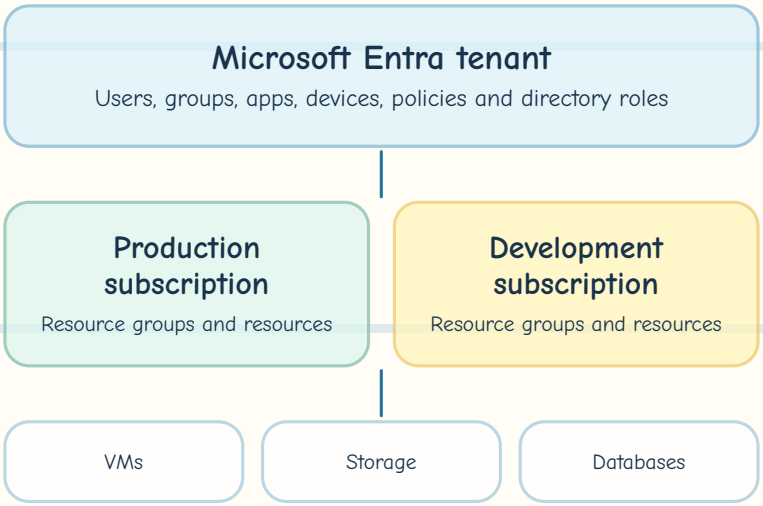
- Is the token valid for me?
- Has it expired?
- Does the identity have the required role?
- Does network access also permit the call?
- Should the operation be allowed or denied?

Identity is one layer of security. Network controls, data permissions, encryption, application rules and auditing still matter.

Tenant, directory and subscription

These words are related, but they describe different boundaries.

Relationship



Remember

Tenant: identity boundary.

Subscription: Azure resource and billing boundary.

Resource group: logical container for related Azure resources.

Definitions

Tenant	An organization's isolated Entra environment. It has a unique tenant ID and its own directory objects and policies.
Directory	The collection of identities and related objects inside the tenant. In everyday usage, tenant and directory are often used almost interchangeably.
Domain	A sign-in name suffix such as **company.onmicrosoft.com** or a verified custom domain such as **company.com**.
Subscription	A container for Azure resources, billing, quotas and Azure RBAC assignments. A tenant can be associated with multiple subscriptions.
Management group	A level above subscriptions used to apply Azure governance and RBAC consistently across many subscriptions.

Example: The same support group can be Reader in Production, Contributor in Development and have no access to the Security subscription.

Common mistake: Creating a user in Entra ID does not automatically give the user access to any Azure subscription or resource.

Users and guest identities

A user object normally represents a person, but its source and relationship to the organization can differ.

Member

A normal internal identity belonging to the organization.

Guest

An external person invited for selected collaboration or application access.

Cloud-only

Created and managed directly in Microsoft Entra ID.

Hybrid

Created in on-premises AD and synchronized to Entra ID.

Important user information

- **User principal name (UPN):** common sign-in name such as vasu@company.com.
- **Object ID:** unique identifier for that directory object.
- **Account status:** enabled or blocked.
- **Department, location and job title:** useful for dynamic groups and governance.
- **Manager:** useful for approvals, access reviews and lifecycle workflows.
- **Authentication methods:** MFA, passkeys, certificates and recovery methods.

Guest access principle

Invite the partner as a guest, then give only the specific group, application or resource role required.

Guest status itself is **not** permission to every company resource.

User lifecycle

Joiner
Create identity, groups, apps and licenses

→

Mover
Change department, role and access

→

Leaver
Block sign-in, revoke sessions and remove access

Good operational checks

- Is the account still required?
- Is the manager correct?
- Are group memberships appropriate?
- Are old authentication methods removed?

Risks to avoid

- Shared human accounts
- Dormant guest users
- Permanent admin rights
- Manual access that survives job changes

User object = identity record. Access comes separately through groups, role assignments, app assignments and policies.

Groups and access assignment

Groups reduce repetitive administration and make access easier to review.

Security group

Used mainly to assign access to Azure resources, applications, file shares and other secured resources.

Microsoft 365 group

Used mainly for collaboration features such as Teams, shared mailbox, calendar and SharePoint site.

Membership methods

Assigned

An administrator or owner manually adds and removes members.

Dynamic user

Membership is calculated from user attributes such as department.

Dynamic device

Membership is calculated from device properties.

```
Example idea:
IF user.department = "Finance"
THEN membership = Finance-Employees
```

Preferred access pattern

Users
Support engineers

→

Group
BOI-App-Support

→

Role assignment
Reader or Contributor

→

Scope
Selected subscription or resource group

Why group-based access?
One role assignment can serve many users. When a person joins or leaves the team, update group membership rather than editing many resources.

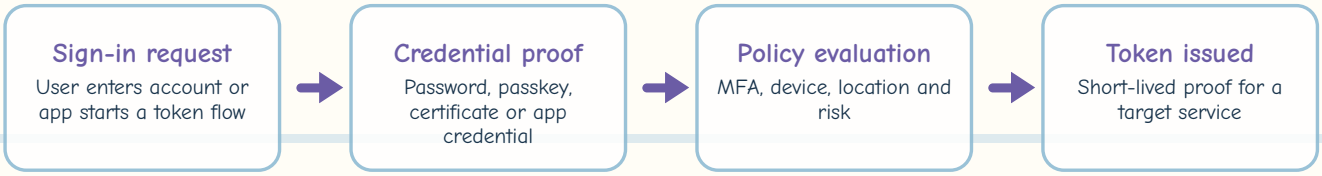
Watch for nested access.
A user may receive access from multiple groups. Review the effective result, especially for privileged roles.

Useful group design rules

- [ ] Name groups by purpose and environment, not by one person's name.
- [ ] Separate Production, PreProduction and Development access.
- [ ] Use owners who can confirm membership is still valid.
- [ ] Use role-assignable groups only when required and protect their membership carefully.
- [ ] Review groups used for privileged access more frequently.

Authentication, MFA and SSO

Authentication proves identity. It does not by itself grant permission to a resource.



Authentication methods

- Password
- Microsoft Authenticator
- Passkey or FIDO2 security key
- Windows Hello for Business
- Certificate-based authentication
- Temporary Access Pass for onboarding and recovery
- Client secret or certificate for some application identities

MFA

Multi-factor authentication uses evidence from more than one category:

Something you know - password or PIN

Something you have - phone, security key or certificate

Something you are - fingerprint or face

Passwordless

Uses a stronger method such as a passkey or Windows Hello, reducing dependence on reusable passwords.

Single Sign-On (SSO)

After authenticating, the user can access integrated applications without entering credentials repeatedly.

Token basics

A token is a time-limited, signed security object containing claims such as the identity, tenant, audience and authentication information. The application or Azure service validates it before considering authorization.

Authentication success can still end in Access Denied. The identity may be valid but lack the required role or data permission.

Security direction: Prefer phishing-resistant authentication for administrators and high-impact users, and do not rely on SMS alone for sensitive access where stronger methods are available.

Permissions, roles and scope

Authorization decides what an authenticated identity is allowed to do.

Security principal + Role + Scope

= Role assignment

Principal — The identity receiving access: user, group, service principal or managed identity.

Permission — One allowed action, such as read a blob, start a VM or reset a password.

Role — A named collection of permissions, such as Reader or Storage Blob Data Contributor.

Scope — Where the role applies. Narrower scope usually means lower risk.

Azure scope hierarchy



Assignments normally inherit downward to child scopes.

Example

Principal: PreProd-App-Support group

Role: Virtual Machine Contributor

Scope: BOI-PreProd resource group

Result: Group members can manage VMs in that resource group, but this assignment does not automatically grant rights in Production.

Least privilege: Give only the role required, at the smallest practical scope, for only as long as needed.

Broad roles: Owner and User Access Administrator can change access. Treat them as high privilege and protect them with PIM and MFA.

Two separate checks may occur

Control plane
Can I configure the Azure resource?

→

Data plane
Can I read or change the data inside it?

Entra roles vs Azure RBAC

Two authorization systems are commonly used together, but they manage different things.

Area	Microsoft Entra role	Azure RBAC role
Controls	Directory objects and identity administration	Azure resources and resource data
Typical targets	Users, groups, applications, domains and policies	VMs, storage, networks, databases and resource groups
Examples	User Administrator, Application Administrator, Global Reader	Reader, Contributor, Virtual Machine Contributor, Storage Blob Data Reader
Main question	What can this person administer in the directory?	What can this identity do to this Azure resource?

Example: A User Administrator can manage user accounts but may have no permission to restart a VM. A VM Contributor can manage VMs but may have no permission to create users.

Storage control plane vs data plane

Control plane

- Create or delete a storage account
- Change networking and redundancy
- Configure lifecycle settings
- View resource properties

Data plane

- Read or upload a blob
- Delete a file
- Read queue messages
- Query table data

Common real-world surprise

A person may be able to open and configure a storage account in the Azure portal but still be unable to list or read its blobs. A data role such as **Storage Blob Data Reader** may also be required.

Role assignment review questions

- [ ] Which identity actually needs access - user, group or workload?
- [ ] Is a built-in role sufficient?
- [ ] Can the assignment be made at resource-group or individual-resource scope?
- [ ] Does the workload need control-plane access, data-plane access or both?
- [ ] Should the assignment be permanent or activated temporarily through PIM?

Conditional Access and related policies

Policies control the conditions under which sign-in is accepted and how authentication is performed.

Conditional Access model

Assignments
Users, groups, workloads and target apps

→

Signals
Location, device, risk, client and platform

→

Decision
Allow, block or require controls

→

Controls
MFA, compliant device, auth strength, session limits

```
Example policy idea:
IF user is an administrator
AND target is Azure management
THEN require phishing-resistant MFA
```

Related identity policies

- **Authentication methods policy:** who can use passkeys, Authenticator, certificates and other methods.
- **Password protection:** blocks weak or banned password patterns.
- **App consent policy:** controls which application permissions users may approve.
- **Session controls:** limit browser sessions or restrict downloads in some scenarios.
- **Security defaults:** a baseline protection option for simpler tenants.

Safe rollout

Start new Conditional Access policies in report-only mode where appropriate, review sign-in impact, exclude emergency access accounts from accidental lockout, then enforce in stages.

Do not confuse these

Control	Main purpose	Example
Conditional Access	Evaluate identity sign-in conditions	Require MFA outside trusted locations
Azure RBAC	Authorize actions on Azure resources	Reader on one resource group
Azure Policy	Evaluate resource configuration and compliance	Storage accounts must disable public access

> **Policy is not permission.** Passing MFA and Conditional Access means the sign-in session is acceptable. The user still needs the correct role or application assignment.

App registration and service principal

Applications need identities too. The application definition and its tenant-specific identity are separate objects.

App registration = blueprint

Service principal = tenant-specific instance

App registration

- Application or client ID
- Redirect URIs
- Requested API permissions
- Application roles
- Certificates, secrets or federation settings
- Single-tenant or multitenant configuration

Service principal

- Application identity inside one tenant
- Receives Azure RBAC roles
- Receives enterprise application assignments
- Represents granted permissions and local policy
- Appears under Enterprise applications

Class and instance analogy

Application object
Common blueprint

→

Service principal
Instance in Tenant A

Service principal
Instance in Tenant B

Service principal
Instance in Tenant C

IDs and credentials

Client ID	Public identifier for the application. It is not a password.
Tenant ID	Identifies the Entra tenant where authentication or consent occurs.
Object ID	Unique ID of a particular directory object, such as the service principal instance.
Client secret	A credential used by some confidential applications. It must be protected and rotated.
Certificate	A stronger credential option for many application scenarios, but still requires lifecycle management.

> **The client ID identifies the app; the secret or certificate proves the app.** Never treat the client ID as confidential.

API permissions, consent and protocols

An application must be allowed to call an API, and the permission model depends on whether a user is present.

Delegated permission

The application acts **on behalf of a signed-in user**.

```
User + App + Delegated permission
            -> API call
```

Effective access is constrained by both the user's authority and the delegated permission granted to the app.

Application permission

The application acts **as itself**, with no user present.

```
Background service
        + App permission
            -> API call
```

Often powerful and normally requires administrator consent.

Consent

Consent is approval for the permissions an application requests. Depending on tenant policy and permission sensitivity, approval may be given by a user for themselves or by an administrator for the organization.

> **High-impact permission:** An application permission that can read all mailboxes or all directory users is much broader than a delegated permission to read the signed-in user's profile. Review purpose, scope and publisher before consent.

Protocol memory map

OAuth 2.0

Framework for obtaining access tokens to call protected APIs.

OpenID Connect

Identity layer on OAuth 2.0, commonly used for modern application sign-in.

SAML

XML-based federation protocol widely used for enterprise SSO to established SaaS applications.

Token checks made by the target API

- [ ] Was the token issued by a trusted authority?
- [ ] Is the token intended for this API (audience)?
- [ ] Has the token expired?
- [ ] Does it contain the required delegated scope or application role?
- [ ] Does the API apply additional business or data authorization?

> **API consent and Azure RBAC are different.** Consent grants an application permission to an API; Azure RBAC grants an identity access to Azure resources.

What is a service account?

Service account is a general operational term for a non-human identity used by software or automation.

Typical service-account workloads

Batch jobs
Nightly reports, reconciliation and housekeeping.

Integration
File transfer, API calls and system-to-system processing.

DevOps
Build, deployment and infrastructure automation.

Monitoring
Health checks, inventory and log collection.

Backups
Scheduled database or file backups.

Applications
Web apps, workers and background services.

Possible technical implementations

Managed identity	Preferred for supported Azure-hosted workloads because Azure manages the credential.
Service principal	Common for external workloads, cross-platform automation or applications needing a tenant identity.
Federated identity	Establishes trust with an external identity provider so a long-lived secret is not required.
User account	Sometimes used by legacy systems, but generally the least desirable model for unattended automation.

Legacy anti-pattern: A scheduled script uses a normal user's username and password stored in a configuration file. Password expiry, MFA, staff departure and weak auditing can all break or expose the process.

Decision guide

Running on an Azure service that supports managed identity?	**Use managed identity** where practical.
External CI/CD or cloud platform supports workload federation?	**Use federated credentials** instead of a stored secret.
Application cannot use either option?	**Use a service principal** with certificate or carefully governed secret.
Legacy system requires a user account?	Document the exception, reduce privileges, protect the credential and monitor usage.

Service account describes the purpose. Service principal and managed identity describe specific Entra identity mechanisms.

Managed identities for Azure resources

A managed identity is an Entra workload identity whose underlying credentials are managed by Azure.

Main benefit: The application can obtain tokens without storing a username, password or client secret in code or configuration.

Area	System-assigned	User-assigned
Creation	Enabled directly on one Azure resource	Created as a separate Azure resource
Relationship	One identity belongs to one resource	One identity can be attached to multiple resources
Lifecycle	Deleted with the parent resource	Independent lifecycle
Typical use	Simple resource-specific access	Shared identity, pre-authorized deployment or stable lifecycle

How the access works

Azure workload
VM, Function, App Service or Automation

→

Managed identity endpoint
Requests token without app secret

→

Entra token
Issued for Storage, Key Vault, SQL, etc.

→

Target service
Checks role and permits or denies operation

Good use cases

- Function reads secrets from Key Vault
- App Service uploads files to Blob Storage
- VM accesses Azure SQL
- Automation account manages selected resources

Identity is not access

Enabling managed identity creates the identity. You must still assign the correct role at the correct scope.

```
Example role assignment:
Principal: OrderProcessing-App managed identity
Role:      Storage Blob Data Contributor
Scope:     Orders storage account or container
```

Common failure: The application obtains a token successfully but receives 403 Forbidden because the managed identity has no data-plane role, the role is at the wrong scope, or the role assignment has not propagated yet.

Choosing a workload identity

Compare lifecycle, credential handling and where the workload runs.

Option	Credential handling	Best fit	Main risks or limits
Human user used by automation	Password and MFA complications	Only unavoidable legacy cases	Shared use, expiry, poor attribution, staff lifecycle
Service principal + secret	Team stores and rotates secret	Broad compatibility	Leakage and expiry; secret inventory required
Service principal + certificate	Team manages certificate lifecycle	Apps needing stronger non-interactive credential	Certificate expiry and private-key protection
Federated service principal	No long-lived Entra secret; external trust used	GitHub, Azure DevOps and supported external platforms	Trust configuration must be tightly scoped
Managed identity	Azure manages underlying credential	Supported Azure-hosted workloads	Primarily tied to Azure scenarios and supported services

Selection map

Azure-hosted? — Prefer **managed identity** where the service and target support Entra authentication.

External platform with OIDC federation? — Prefer **workload identity federation**.

No federation support? — Use **service principal + certificate** where practical, otherwise a tightly governed secret.

Needs a human session? — Use a normal user identity, not a workload identity, and apply MFA and Conditional Access.

Lifecycle controls

Before deployment

- Named owner
- Business purpose
- Least-privilege role
- Defined scope
- Expiry or review date

During operation

- Monitor sign-ins
- Rotate credentials
- Remove unused permissions
- Review owners
- Delete retired identities

Preferred order: managed identity - federated credential - certificate - client secret - human user account used by automation.

Device identities and hybrid identity

Access decisions can consider both the user and the device being used.

Entra registered

Often personal or BYOD devices where a work account is added.

Entra joined

Organization-owned device joined directly to Microsoft Entra ID.

Hybrid joined

Device belongs to on-premises AD and is also represented in Entra ID.

Conditional Access example: Permit a finance application only when the user completes MFA and the laptop is marked compliant by device management.

Hybrid identity flow

On-premises AD
Traditional users, groups and computers

→

Sync service
Entra Connect or Cloud Sync

→

Microsoft Entra ID
Cloud sign-in and application access

→

Cloud services
Azure, Microsoft 365 and SaaS

Entra ID vs Active Directory Domain Services

Microsoft Entra ID	Active Directory Domain Services
Cloud identity and access management	Traditional Windows domain directory
OAuth 2.0, OpenID Connect and SAML	Kerberos, NTLM and LDAP
Conditional Access and cloud SSO	Domain join and Group Policy
No customer-managed domain controller required	Domain controllers are required and managed

Legacy application need: If an application requires LDAP, Kerberos or classic domain join, evaluate on-premises AD DS or Microsoft Entra Domain Services rather than assuming Entra ID alone provides those protocols.

Synchronization is not the same as backup. Identity changes, including unwanted changes, can synchronize. Governance and recovery planning are still required.

PIM, access reviews and identity risk

Governance ensures access remains appropriate after it is initially granted.

Privileged Identity Management (PIM)

Provides eligible, time-limited activation of privileged Entra and Azure roles.

```
Eligible role -> activate -> MFA/
approval
-> temporary access -> automatic expiry
```

Access reviews

Periodically ask whether users, guests or administrators still need group, application or role access.

Identity Protection

Detects risky users and risky sign-ins using identity risk signals.

Lifecycle workflows

Automates joiner, mover and leaver identity tasks.

Entitlement management

Packages access, approvals and expiry for governed access requests.

Joiner - mover - leaver control

Joiner
Provision account and baseline access

→

Mover
Remove old access before adding new access

→

Leaver
Block sign-in, revoke tokens and remove ownership

Logs you should know

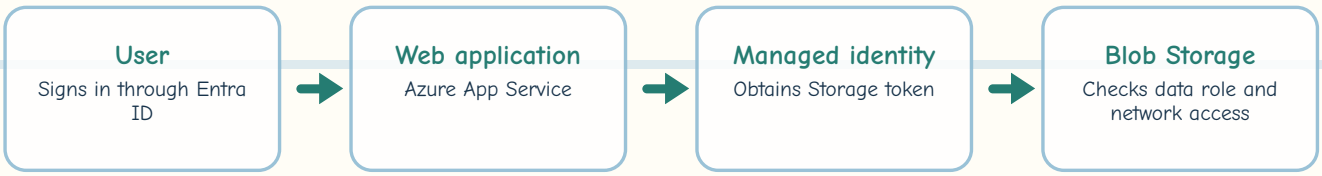
Sign-in logs	Who or what signed in, from where, to which app, using which authentication and policy result.
Audit logs	Changes to directory objects such as users, groups, app registrations, role assignments and policies.
Provisioning logs	Automated user or group provisioning activity between Entra ID and connected applications.
Risk reports	Detected risky users, sign-ins and related remediation status.

> **Governance question:** Not only "Who has access today?" but also "Why do they have it, who approved it, when was it last reviewed, and when should it expire?"

App Service accessing Blob Storage

This scenario combines a human identity, a workload identity, Conditional Access and Azure RBAC.

Architecture



User side

1. User opens the web application.
2. Application redirects sign-in to Entra ID.
3. MFA or Conditional Access may apply.
4. Application receives identity information and creates a user session.
5. Application applies its own business authorization.

Application side

1. App Service requests a token using managed identity.
2. Token is requested for Azure Storage.
3. App calls Blob Storage with the token.
4. Storage checks Azure RBAC data permissions.
5. Storage also enforces firewall or private endpoint rules.

```
Example authorization:
Principal: App Service managed identity
Role:      Storage Blob Data Contributor
Scope:     Specific storage account or container
```

Why this pattern is safer

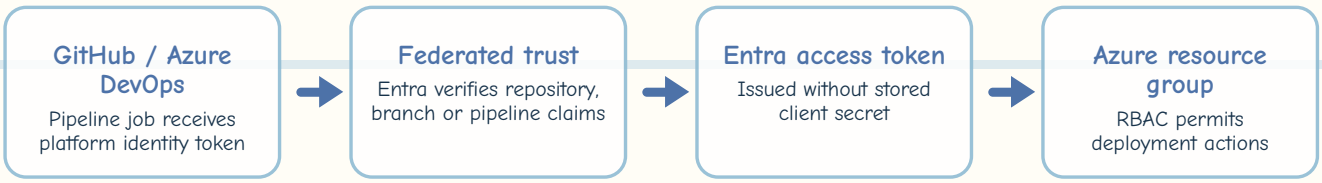
- [ ] No storage account key is embedded in application code.
- [ ] No client secret must be manually rotated for the Azure-hosted workload.
- [ ] The role can be limited to one storage account or container.
- [ ] User permissions and application permissions remain separate and auditable.

Troubleshooting: A 403 can mean missing Blob data role, wrong managed identity, wrong scope, network denial, expired token or application-level denial. Check both identity and network layers.

CI/CD pipeline deploying to Azure

Modern pipelines should avoid long-lived secrets where workload identity federation is supported.

Federated deployment pattern



Good design

- Separate identities for Production and non-Production
- Trust only the required repository, branch or environment
- Assign role at resource-group scope where possible
- Use approval gates for Production
- Monitor service-principal sign-ins and deployments

Risky design

- One Owner identity shared across all subscriptions
- Client secret stored permanently in pipeline variables
- No owner or purpose recorded
- Production deployment from any branch
- Old service principals never removed

Fast failure diagnosis

Symptom	Likely area	Checks
401 Unauthorized	Authentication or token	Tenant, client ID, credential/federation, audience, token expiry
403 Forbidden	Authorization or policy	RBAC role, scope, data action, app permission, Conditional Access
Timeout / refused	Network or service availability	DNS, firewall, private endpoint, route, proxy, service status
Worked yesterday	Lifecycle change	Expired secret/certificate, removed role, policy change, rotated key

Diagnostic order: identify the caller - confirm token acquisition - inspect token target - check role and scope - check target data permission - check network - review logs.

Entra ID security best practices

Use these as practical design and review rules rather than as a one-time configuration exercise.

Identity principles

- [ ] Use least privilege and the smallest practical scope.
- [ ] Assign routine access through groups rather than individual users.
- [ ] Require strong MFA, especially for administrators.
- [ ] Use PIM for temporary privileged access.
- [ ] Maintain emergency access accounts and protect them carefully.
- [ ] Separate Production and non-Production identities and permissions.
- [ ] Avoid shared administrator accounts.

Workload principles

- [ ] Prefer managed identity for supported Azure workloads.
- [ ] Prefer workload federation for supported external pipelines.
- [ ] Do not put secrets in source code or shell scripts.
- [ ] Give every app identity an owner and purpose.
- [ ] Review high-impact API consent.
- [ ] Rotate remaining secrets and certificates before expiry.
- [ ] Remove identities when the workload is retired.

Operational review checklist

Daily / alert driven

- Risky sign-ins
- Privilege changes
- Unexpected app activity
- Authentication failures

Monthly / quarterly

- Guest access
- Privileged groups
- App permissions
- Unused accounts

Before a change

- Impact and rollback
- Emergency exclusion
- Report-only testing
- Audit evidence

Production caution: Test Conditional Access and role changes with controlled accounts. A mistaken policy can block administrators; an overly broad role can expose the entire environment.

Evidence to capture for support and audit

- Who requested and approved access
- Principal, role and exact scope
- Start date, expiry date and business justification
- Relevant sign-in or audit log correlation details
- Proof of removal after the change or review period

Good identity security is continuous: provision - protect - monitor - review - remove.

Recommended learning order and labs

Learn the concepts in layers, then confirm each layer with a small hands-on exercise.

Learning sequence

1. Identity, authentication and authorization
2. Tenant, directory, domain and subscription
3. Users, guests and groups
4. Entra roles and Azure RBAC
5. MFA and Conditional Access
6. App registration and service principal
7. API permissions and consent
8. Managed identities and workload federation
9. Hybrid identity and device identity
10. PIM, access reviews, logs and lifecycle

Study rule

For every topic, answer:

1. What identity is involved?
2. How does it authenticate?
3. Which policy applies?
4. Which permission or role is required?
5. At what scope?

Hands-on lab ideas

- [ ] Create a test user and security group.
- [ ] Add the user to the group and inspect membership.
- [ ] Assign Reader to the group on a test resource group.
- [ ] Compare what the user can view and cannot change.
- [ ] Inspect a built-in Azure role definition.
- [ ] Create an app registration in a test tenant.
- [ ] Locate its service principal under Enterprise applications.
- [ ] Enable managed identity on a test Azure resource.
- [ ] Assign a narrow Blob data role and test access.
- [ ] Review sign-in and audit logs after each activity.

> **Safe lab boundary:** Use a sandbox subscription and non-sensitive data. Do not experiment with broad roles or Conditional Access in a Production tenant without change control and recovery planning.

Microsoft Learn topics to revisit

Microsoft Entra fundamentals; authentication methods; Conditional Access; Azure RBAC; app objects and service principals; managed identities; identity governance; hybrid identity; workload identity federation.

Plain-language glossary

Quick definitions for the terms most often used in Azure identity discussions.

Identity	A representation of a person, workload or device.
Tenant	Organization's isolated Entra boundary.
Directory	Collection of objects inside the tenant.
UPN	Common user sign-in name.
Group	Collection used to manage people, devices or access.
Authentication	Proving who or what the caller is.
Authorization	Deciding which actions the caller may perform.
MFA	Authentication using more than one factor category.
SSO	One sign-in used across integrated applications.
Token	Short-lived signed proof presented to a service.
Claim	A piece of information carried inside a token.
Principal	Identity to which access can be assigned.
Permission	One allowed operation.
Role	Named collection of permissions.
Scope	Boundary where an assignment applies.
RBAC	Role-based access control.
App registration	Application definition or blueprint.
Service principal	Application identity in one tenant.
Enterprise app	Administrative view of a tenant's service principal.
Service account	General term for a non-human automation identity.
Managed identity	Azure-managed workload identity.
Consent	Approval of an application's requested API permissions.
PIM	Time-limited privileged role activation and governance.
Conditional Access	Policy engine evaluating sign-in conditions and controls.

Fast formula: Identity proves itself through authentication. Policy decides whether the session is acceptable. Authorization checks role or permission at a scope. The target resource then allows or denies the operation.

One-page Entra ID cheat sheet

Use this final page before a meeting, change, interview or troubleshooting call.

Core memory map

Tenant = identity boundary

User = human identity

Group = collection of identities

Authentication = prove identity

Authorization = decide allowed actions

Role assignment = principal + role + scope

Workload memory map

App registration = blueprint

Service principal = app identity in tenant

Service account = general non-human account term

Managed identity = Azure-managed workload identity

Consent = approval for API permissions

Federation = trust without long-lived Entra secret

Before granting access, ask

WHO?
User, group, app or managed identity

WHAT?
Exact role or API permission

WHERE?
Tenant, subscription, RG, resource or data

WHEN?
Permanent, temporary or expiring

WHY?
Business purpose and approval

HOW CHECKED?
Logs, reviews and monitoring

Quick troubleshooting order

Caller
Which identity?

→

Token
Obtained for correct audience?

→

Permission
Correct role, scope or API grant?

→

Network
Firewall, DNS and private endpoint?

→

Logs
Sign-in, audit and resource diagnostics

Self-check questions

1. Why can authentication succeed but an operation still fail?

2. How is a service principal different from an app registration?

3. Why does managed identity still need an RBAC assignment?

4. What is the difference between Entra roles and Azure RBAC roles?

5. When would application permission be used instead of delegated permission?

6. Which identity option avoids a stored secret for an Azure-hosted app?

Final sentence: Microsoft Entra ID is the identity control plane that authenticates people and workloads, applies access policy, issues tokens and supports authorization across Microsoft cloud and connected applications.